Enterprise Cryptography, Key Management & Cloud Data Standard

Document ID: STD-CRYPTO-02-EN | Version: 2.0 | Clearance: Internal / IT-Admin (Min. Role L1/L2)

§ 1 Approved Cryptographic Primitives & Cipher Suites

This technical standard defines mandatory cryptographic controls (Verschlüsselungsvorgaben) in alignment with BSI TR-02102-1 and NIST SP 800-57. All internal and external IT systems, cloud workloads, databases, and communication channels must exclusively implement the approved cryptographic primitives listed below:

Use Case / Layer	Mandatory Algorithm & Minimum Key Length	Key Rotation / Validity	Explicitly Prohibited (Legacy)
Data at Rest (Storage / DB / Backup)	**AES-256-GCM** or **ChaCha20-Poly1305** (Full Disk: XTS-AES-256)	Master Key: **12 Monate** (1 year); DEK: per volume	3DES, Blowfish, RC4, AES-128-ECB, unencrypted snapshots
Data in Transit (Web / API / VPN)	**TLS 1.3** (or TLS 1.2 with ECDHE + AES-256-GCM PFS); IPSec IKEv2 / WireGuard	TLS Certificates: max. **90 Tage** (automated via ACME)	SSLv3, TLS 1.0, TLS 1.1, RSA key transport without PFS
Asymmetric Signing & SSH	**Ed25519**, **ECDSA P-384**, or **RSA-4096**	SSH Host & User Keys: **180 Tage** (6 Monate)	RSA-1024, RSA-2048 (for new root CAs), DSA, SHA-1 signatures
Password & Secret Hashing	**Argon2id** (min. 64 MB memory, 3 iterations) or PBKDF2-HMAC-SHA512	Immediate re-hash upon policy upgrade or compromise	MD5, SHA-1, unsalted SHA-256, bcrypt with cost < 10
Post-Quantum Hybrid (Critical Links)	**ML-KEM-768 (Kyber)** + X25519 hybrid key exchange	Session ephemeral keys rotated every **60 Minuten**	Non-hybrid classical key exchange on Tier-1 dark fiber links

§ 2 Key Management Lifecycle & Hardware Security Modules (HSM)

Cryptographic keys must never be hardcoded in application source code, container images, or Git repositories. All Customer Master Keys (CMKs) and Certificate Authority (CA) private keys must be generated and stored inside dedicated **FIPS 140-3 Level 3 Hardware Security Modules (HSM)**. Access to root key material requires split-knowledge dual control (Four-Eyes Principle / M-of-N Shamir Secret Sharing with at least **3 of 5 key custodians**). Suspected compromise of any cryptographic key requires emergency revocation and re-keying within **4 Stunden** (4 hours).

§ 3 Cloud Data Sovereignty, BYOK & Temporary Migration Exceptions

When utilizing external Cloud Service Providers (IaaS, PaaS, SaaS) for **Confidential (Vertraulich)** data, Customer-Managed Keys via **Bring Your Own Key (BYOK)** or Hold Your Own Key (HYOK) are mandatory. The external cloud provider must be audited for ISO/IEC 27017 and C5 compliance at least once every **24 Monate** (2 Jahre / biennial audit cycle).

Strictly Confidential Data (Streng Vertraulich / Class 3) Exception Rule: While permanent storage of Strictly Confidential data in public clouds is generally restricted, this technical standard permits temporary staging of Strictly Confidential data in a certified EU/EEA public cloud environment for up to **14 Tage** (14 days) during disaster recovery migrations or high-performance computing bursts, provided that client-side envelope encryption (HYOK) is enforced prior to upload.

§ 4 Certificate Automation, Log Signing & Legacy Deprecation

To prevent service outages caused by expired TLS certificates, all internal and public-facing endpoints must use automated certificate lifecycle management (ACME protocol) with a maximum certificate validity of **90 Tage** (90 days) and automated renewal triggered **30 Tage** prior to expiration. Furthermore, all compliance audit trails and security logs exported under NIS-2 or ISO 27001 must be cryptographically chained using **SHA-256** and signed with an offline-rooted Ed25519 key so that any retroactive tampering is mathematically detectable. Systems unable to support TLS 1.2 or AES-256 must be isolated in a restricted legacy VLAN and decommissioned within **6 Monate**.

> **Governance & Conflict Verification Note (Pipeline A Test Case):** Section 3 of this standard introduces two deliberate deviations against *cloud_security_policy_2026.pdf (SEC-POL-CLOUD-04)*: 1. It extends the Cloud Provider Audit interval to **24 Monate (2 Jahre)** instead of an annual (jährlich / 12 Monate) audit.
> 2. It allows temporary processing of **Strictly Confidential (Streng Vertraulich)** data in a public cloud for up to **14 Tage** with HYOK encryption, whereas *SEC-POL-CLOUD-04 § 2* enforces a zero-exception On-Premise mandate.